

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 09

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM3-001)

Which statement BEST describes how information security governance contributes to enterprise value?

- A. It maximizes security spending independently of business priorities.
- B. It balances protection, resource use, and risk decisions with enterprise objectives.
- C. It transfers accountability for information risk to the security function.
- D. It guarantees that all adverse information events will be prevented.

Question 2 (CISM3-002)

Scenario: At an engineering company, employees who report security mistakes are publicly criticized. Business units now conceal near misses, leaving leaders with an incomplete view of risk.

What should the information security manager recommend FIRST?

- A. Establish leadership-supported, nonpunitive reporting expectations while preserving accountability for misconduct.
- B. Limit incident reporting to security personnel.
- C. Increase penalties for late reporting without changing management behavior.
- D. Replace the incident reporting platform.

Question 3 (CISM3-003)

Scenario: A travel services group plans to centralize customer records from several jurisdictions. Legal teams identify different retention and transfer obligations, while the architecture team wants a single global process.

What is the BEST governance approach?

- A. Apply the shortest retention period to every record without impact analysis.
- B. Map applicable obligations to information flows and establish accountable decisions for jurisdictional variations.
- C. Let the architecture team interpret legal requirements independently.
- D. Retain all records indefinitely to avoid accidental deletion.

Question 4 (CISM3-004)

Who should normally accept residual information risk on behalf of a business process?

- A. The control tester who identified the weakness
- B. The technology supplier supporting the process
- C. Any administrator assigned to the affected system
- D. The authorized business risk owner

Question 5 (CISM3-005)

Scenario: The security manager reports to the executive responsible for meeting an aggressive system launch date. That executive repeatedly suppresses reports of material security exposure that could delay the launch.

Which governance change would BEST address the problem?

- A. Require security analysts to resolve all exposures without business involvement.
- B. Allow the launch executive to remove risks from the enterprise register.
- C. Create an independent escalation path to an authorized risk or governance forum.
- D. Stop reporting launch-related risk until the project is complete.

Question 6 (CISM3-006)

Scenario: A retail group acquires three companies with different identity processes, customer information models, and technology platforms. Executives want rapid integration without creating redundant security capabilities.

What should the information security manager do FIRST?

- A. Purchase one identity product before assessing business processes.
- B. Require each acquired company to preserve its existing architecture permanently.
- C. Map current capabilities with enterprise architects and define target-state security requirements.
- D. Limit the integration review to technical vulnerability scans.

Question 7 (CISM3-007)

Why is enterprise architecture relevant to an information security manager?

- A. It connects the business, information, applications, and technology supporting security decisions.
- B. It makes security governance unnecessary once technologies are standardized.
- C. It assigns all business process ownership to technology teams.
- D. It consists primarily of detailed network configuration instructions.

Question 8 (CISM3-008)

Scenario: A pension administrator will outsource a critical records service. The proposed contract promises strong security but lacks incident notification times, assurance rights, subcontractor obligations, and exit support.

What should the information security manager recommend?

- A. Accept the contract because general security promises are sufficient.
- B. Define measurable obligations, oversight rights, accountability, and transition requirements before approval.
- C. Transfer accountability for regulatory compliance entirely to the provider.
- D. Rely on the provider's marketing materials instead of enforceable terms.

Question 9 (CISM3-009)

Scenario: During service outages, database administrators can grant themselves emergency access, make changes, and close their own access records. Management cannot add staff to every overnight shift.

Which control arrangement is MOST appropriate?

- A. Prohibit all emergency access outside normal business hours.
- B. Permit emergency access with logged use and timely independent review by an authorized person.
- C. Allow administrators to review their own activity if they document the outage.
- D. Give permanent elevated access to avoid emergency approvals.

Question 10 (CISM3-010)

Scenario: A manufacturer has accumulated dozens of architecture exceptions to meet production deadlines. Some exceptions affect critical production capabilities, while others concern systems scheduled for retirement.

What should the information security manager recommend FIRST?

- A. Remediate exceptions in the order they were recorded.
- B. Accept every exception until the next architecture redesign.
- C. Require immediate replacement of every affected system.
- D. Assess business impact, risk, target architecture, and system lifecycle to prioritize treatment.

Question 11 (CISM3-011)

Which event is MOST likely to require an out-of-cycle information security strategy review?

- A. A routine weekly operations meeting
- B. Completion of a scheduled software update
- C. A material change in enterprise objectives or risk conditions
- D. A minor change to an internal meeting agenda

Question 12 (CISM3-012)

Scenario: A university's security roadmap lists twelve technology projects but does not describe the security capabilities or business outcomes expected after completion.

Why is defining the desired state important?

- A. It removes the need to assess the current state.
- B. It guarantees that every proposed technology project will be funded.
- C. It provides target capabilities and outcomes against which gaps and initiatives can be evaluated.
- D. It allows technical teams to set enterprise objectives independently.

Question 13 (CISM3-013)

Scenario: A medical equipment producer learns that several critical component suppliers are exposed to a new class of disruption. The current strategy does not address supplier resilience beyond initial contract review.

What should the information security manager do NEXT?

- A. Terminate every supplier relationship immediately.
- B. Purchase monitoring technology before defining the required capability.
- C. Leave the issue entirely to procurement because it involves suppliers.
- D. Assess strategic exposure and revise supplier-resilience objectives and initiatives as warranted.

Question 14 (CISM3-014)

Scenario: A holding company includes a regulated lender, a small marketing agency, and an industrial operator. Leadership wants one security framework applied identically to every subsidiary.

What is the BEST recommendation?

- A. Establish common governance principles and tailor implementation to risk, obligations, and operating context.
- B. Apply the most stringent control to every asset without considering risk.
- C. Allow every subsidiary to ignore enterprise governance practices.
- D. Select separate unrelated frameworks with no enterprise mapping.

Question 15 (CISM3-015)

Scenario: A shipping company must reduce its security budget by 20 percent. Proposed work includes a mandatory port-access requirement, foundational data ownership, a cosmetic dashboard redesign, and replacement of a stable low-risk tool.

Which action is MOST appropriate?

- A. Protect the mandatory and foundational work while deferring lower-value discretionary items.
- B. Reduce funding equally across all initiatives.
- C. Fund only the most visible initiative for executive reporting.
- D. Cancel all strategic work and reserve the budget for incident response.

Question 16 (CISM3-016)

Scenario: The chief operating officer supports a security modernization program, but business executives refuse to change processes needed for it. The security manager has been reporting only technical milestones.

What should the information security manager do FIRST?

- A. Remove business-dependent outcomes from the strategy.
- B. Continue technical implementation without business process changes.
- C. Assign all business changes to the security engineering team.
- D. Present required changes, owners, benefits, and unresolved decisions to the steering forum.

Question 17 (CISM3-017)

Scenario: A property management company's security roadmap schedules automated authorization before completing role ownership and application inventory initiatives on which the automation depends.

What should the information security manager recommend?

- A. Proceed because technology can compensate for undefined ownership.
- B. Resequence the roadmap so foundational ownership and inventory capabilities precede automation.
- C. Run every initiative simultaneously without shared milestones.
- D. Cancel role ownership because it is not a technical control.

Question 18 (CISM3-018)

Scenario: An energy distributor's strategic objective is to reduce exposure from overdue critical vulnerabilities. Its report shows only the total number of scans performed.

Which measure BEST reflects the intended outcome?

- A. The number of scanning servers deployed
- B. The number of pages in the vulnerability procedure
- C. The number of employees who can access scan reports
- D. The percentage of critical vulnerabilities remaining open beyond the approved risk threshold

Question 19 (CISM3-019)

Scenario: A broadcasting company will move from regional content systems to a shared digital platform. Regional leaders request long-term investments in separate controls, while the approved target architecture requires common protection capabilities.

What is the BEST investment approach?

- A. Prioritize shared target capabilities while funding only necessary interim controls for material transition risk.
- B. Fund every regional request to avoid stakeholder disagreement.
- C. Stop protecting regional systems as soon as the target architecture is approved.
- D. Exclude enterprise architects from security investment decisions.

Question 20 (CISM3-020)

Scenario: A legal services network approves eight concurrent security initiatives, but the same two specialists are required for six of them. Project schedules do not account for this constraint.

What should the information security manager do NEXT?

- A. Keep all dates unchanged and assume the specialists will absorb the workload.
- B. Reassess capacity, dependencies, sequencing, and sourcing options before committing to delivery dates.
- C. Remove resource assumptions from roadmap reporting.
- D. Purchase unrelated security tools to demonstrate progress.

Question 21 (CISM3-021)

What is the PRIMARY purpose of an information security standard?

- A. To define mandatory, specific requirements that support policy objectives
- B. To record every security incident affecting the enterprise
- C. To authorize business owners to ignore enterprise policy
- D. To provide optional suggestions with no relationship to policy

Question 22 (CISM3-022)

Scenario: A regional bank can build an internal fraud-monitoring capability, use a shared industry service, or adopt a hybrid model. Each option differs in time to value, expertise, data exposure, cost, and oversight needs.

How should the information security manager recommend an option?

- A. Choose the internal option because strategic capabilities may never use external support.
- B. Choose the lowest initial price without considering lifecycle costs.
- C. Allow the selected provider to accept the bank's residual risk.
- D. Compare each model against required outcomes, risk, total cost, capability, oversight, and exit needs.

Question 23 (CISM3-023)

Scenario: A sales division requests a six-month exception from a data protection standard to launch a pilot. The policy does not specify who may approve exceptions or how they should be monitored.

What should the information security manager establish FIRST?

- A. A rule that the security manager personally accepts all business risk.
- B. Automatic approval for every time-limited pilot.
- C. Authorized approval thresholds, risk assessment criteria, expiration, treatment, and monitoring requirements.
- D. Permanent exceptions for initiatives with revenue potential.

Question 24 (CISM3-024)

Scenario: A telecommunications provider has spent its full security budget and completed every planned procurement. However, critical service disruptions have increased and resilience targets are repeatedly missed.

What is the MOST appropriate conclusion?

- A. The strategy's assumptions, initiatives, and measures require review because outputs are not achieving outcomes.
- B. The strategy is successful because budget execution reached 100 percent.
- C. Future reports should omit resilience targets.
- D. The organization should repeat the same investments with a larger budget.

Question 25 (CISM3-025)

Scenario: An online brokerage states that it has little appetite for unauthorized transaction risk and defines a maximum approved level of unresolved high-risk access conflicts.

How should the defined maximum be used?

- A. As an informal target that has no effect on escalation
- B. As permission to ignore unauthorized transaction risk below the maximum
- C. As a measurable boundary for monitoring, escalation, and treatment decisions
- D. As a replacement for all management judgment and risk analysis

Question 26 (CISM3-026)

Scenario: Plant managers view a new security strategy as a corporate technology program and do not understand why their maintenance processes must change.

How should the information security manager respond?

- A. Send the complete technical architecture without additional context.
- B. Explain relevant business risks, expected operational outcomes, responsibilities, and implementation impacts.
- C. Exclude plant managers from planning because they are not security specialists.
- D. Require immediate compliance without identifying process ownership.

Question 27 (CISM3-027)

Scenario: A business-to-business distributor acquires a consumer marketplace and plans to integrate it within nine months. The existing security strategy assumes few known corporate customers, predictable transaction volumes, and no consumer data processing.

What should the information security manager do FIRST?

- A. Apply the existing strategy unchanged to preserve consistency.
- B. Purchase consumer security tools before completing strategic analysis.
- C. Reassess objectives, threats, dependencies, and capability gaps created by the acquisition.
- D. Delegate strategy ownership to the acquired marketplace's technology team.

Answer Key

Domain I - Information Security Governance

1 B	2 A	3 B	4 D	5 C
6 C	7 A	8 B	9 B	10 D
11 C	12 C	13 D	14 A	15 A
16 D	17 B	18 D	19 A	20 B
21 A	22 D	23 C	24 A	25 C
26 B	27 C			

Detailed Explanations

Question 1 (CISM3-001)

Correct answer: B - It balances protection, resource use, and risk decisions with enterprise objectives.

Security governance contributes value by aligning protection, resources, and risk decisions with enterprise objectives. Maximizing spending without business context can waste resources, accountability remains with appropriate enterprise owners, and governance cannot guarantee prevention of every adverse event.

Question 2 (CISM3-002)

Correct answer: A - Establish leadership-supported, nonpunitive reporting expectations while preserving accountability for misconduct.

Leadership-supported, nonpunitive reporting encourages transparency while still distinguishing mistakes from deliberate misconduct. Additional penalties can deepen concealment, restricting reports reduces visibility, and a new platform does not correct the cultural barrier.

Question 3 (CISM3-003)

Correct answer: B - Map applicable obligations to information flows and establish accountable decisions for jurisdictional variations.

Mapping obligations to information flows and accountable decisions enables a consistent architecture with justified jurisdictional variations. A universal shortest period may breach other duties, architects should not interpret law alone, and indefinite retention can create additional legal and risk exposure.

Question 4 (CISM3-004)

Correct answer: D - The authorized business risk owner

The authorized business risk owner is accountable for accepting residual risk within delegated authority. Testers provide findings, suppliers support services, and administrators operate systems but do not automatically possess authority to accept enterprise business risk.

Question 5 (CISM3-005)

Correct answer: C - Create an independent escalation path to an authorized risk or governance forum.

An independent escalation path prevents one delivery executive from suppressing material information needed by authorized decision-makers. Removing risks from the register weakens transparency, analysts cannot unilaterally resolve business exposure, and delayed reporting denies leaders timely oversight.

Question 6 (CISM3-006)

Correct answer: C - Map current capabilities with enterprise architects and define target-state security requirements.

Mapping current capabilities and defining target-state security requirements provides a business-aligned basis for integration and investment. Premature purchasing may not fit the operating model, permanent separation preserves duplication, and vulnerability scans do not address capabilities, information, processes, or architecture direction.

Question 7 (CISM3-007)

Correct answer: A - It connects the business, information, applications, and technology supporting security decisions.

Enterprise architecture provides a business-aligned view of capabilities, processes, information, applications, and technology that informs security governance. It does not replace governance, transfer all process ownership to technology, or consist only of detailed network configurations.

Question 8 (CISM3-008)

Correct answer: B - Define measurable obligations, oversight rights, accountability, and transition requirements before approval.

Measurable contractual obligations and oversight provisions make expectations enforceable and support continuing governance throughout the service lifecycle. General promises and marketing claims are insufficient, while outsourcing service delivery does not transfer the administrator's accountability for its obligations.

Question 9 (CISM3-009)

Correct answer: B - Permit emergency access with logged use and timely independent review by an authorized person.

Logged emergency access followed by prompt independent review provides operational flexibility while compensating for limited real-time segregation. Prohibiting access could extend outages, self-review preserves the conflict, and permanent privileges increase exposure beyond the emergency need.

Question 10 (CISM3-010)

Correct answer: D - Assess business impact, risk, target architecture, and system lifecycle to prioritize treatment.

Prioritization should consider business criticality, exposure, target architecture, and remaining system life so resources address the most meaningful risk. Record age alone is weak, blanket acceptance lacks governance, and universal immediate replacement may be disproportionate or wasteful.

Question 11 (CISM3-011)

Correct answer: C - A material change in enterprise objectives or risk conditions

A material change in enterprise objectives or risk conditions can invalidate strategic assumptions and requires timely reassessment. Routine meetings, scheduled operational updates, and minor administrative changes ordinarily do not justify an out-of-cycle strategy review.

Question 12 (CISM3-012)

Correct answer: C - It provides target capabilities and outcomes against which gaps and initiatives can be evaluated.

The desired state defines target capabilities and outcomes, enabling meaningful gap analysis and initiative selection. It does not guarantee funding, replace current-state analysis, or transfer enterprise objective setting to technical teams.

Question 13 (CISM3-013)

Correct answer: D - Assess strategic exposure and revise supplier-resilience objectives and initiatives as warranted.

The new external condition should be assessed for enterprise impact and reflected in strategic objectives and initiatives when material. Universal termination is disproportionate, technology selection should follow capability needs, and procurement participation does not remove security's strategic governance role.

Question 14 (CISM3-014)

Correct answer: A - Establish common governance principles and tailor implementation to risk, obligations, and operating context.

Common principles provide enterprise consistency, while tailored implementation recognizes different risks, obligations, and business models. No common practices weakens oversight, universal maximum controls may be disproportionate, and unrelated frameworks impede consolidated governance and reporting.

Question 15 (CISM3-015)

Correct answer: A - Protect the mandatory and foundational work while deferring lower-value discretionary items.

Mandatory and foundational initiatives should be protected because they address obligations and enable broader strategy, while cosmetic or low-risk replacements can be deferred. Equal cuts ignore priority, visibility is not value, and canceling all strategic work sacrifices sustainable risk management.

Question 16 (CISM3-016)

Correct answer: D - Present required changes, owners, benefits, and unresolved decisions to the steering forum.

The steering forum needs visibility into required business changes, ownership, value, and unresolved decisions so sponsorship becomes actionable. Technical progress alone cannot deliver process outcomes, engineers cannot own all business change, and removing necessary outcomes would weaken alignment.

Question 17 (CISM3-017)

Correct answer: B - Resequence the roadmap so foundational ownership and inventory capabilities precede automation.

Automation requires reliable ownership and inventory context, so foundational capabilities should precede dependent implementation. Technology cannot resolve undefined authority, role ownership is essential governance, and uncoordinated parallel work increases delivery and integration risk.

Question 18 (CISM3-018)

Correct answer: D - The percentage of critical vulnerabilities remaining open beyond the approved risk threshold

The percentage of critical vulnerabilities beyond the approved threshold directly reflects residual exposure and the strategy's intended outcome. Scanner counts, procedure length, and report access measure resources or administration rather than risk reduction.

Question 19 (CISM3-019)

Correct answer: A - Prioritize shared target capabilities while funding only necessary interim controls for material transition risk.

Investments should build reusable target capabilities while maintaining proportionate interim protection during transition. Funding all regional requests can create stranded cost, immediate withdrawal of legacy protection creates exposure, and architecture collaboration is essential to aligned investment decisions.

Question 20 (CISM3-020)

Correct answer: B - Reassess capacity, dependencies, sequencing, and sourcing options before committing to delivery dates.

Capacity and dependency analysis is necessary to create a credible roadmap and determine whether sequencing, training, hiring, or sourcing is appropriate. Assuming unlimited workload invites failure, hiding assumptions weakens oversight, and unrelated tools do not resolve the constrained expertise.

Question 21 (CISM3-021)

Correct answer: A - To define mandatory, specific requirements that support policy objectives

Standards translate policy direction into mandatory and specific requirements. Optional advice is normally guidance, incident records serve operational purposes, and standards do not authorize business owners to disregard enterprise policy.

Question 22 (CISM3-022)

Correct answer: D - Compare each model against required outcomes, risk, total cost, capability, oversight, and exit needs.

A structured comparison across outcomes, risk, lifecycle cost, capability, oversight, and exit needs supports a defensible sourcing decision. Internal delivery is not universally required, initial price is incomplete, and service providers do not assume the bank's authority to accept enterprise risk.

Question 23 (CISM3-023)

Correct answer: C - Authorized approval thresholds, risk assessment criteria, expiration, treatment, and monitoring requirements.

A governed exception process requires authorized decision rights, consistent risk criteria, expiration, treatment, and monitoring. Time limits alone do not justify automatic approval, the security manager should not accept all business risk, and revenue potential does not justify permanent deviation.

Question 24 (CISM3-024)

Correct answer: A - The strategy's assumptions, initiatives, and measures require review because outputs are not achieving outcomes.

Completed spending and procurement are outputs, while worsening disruptions and missed targets show that intended outcomes are not being achieved. Removing targets hides performance, and repeating investments without reviewing assumptions and effectiveness may compound the problem.

Question 25 (CISM3-025)

Correct answer: C - As a measurable boundary for monitoring, escalation, and treatment decisions

A defined tolerance provides a measurable boundary that supports monitoring, escalation, and treatment consistent with broader risk appetite. It is not merely informal, does not make lower exposure irrelevant, and informs rather than replaces management judgment and analysis.

Question 26 (CISM3-026)

Correct answer: B - Explain relevant business risks, expected operational outcomes, responsibilities, and implementation impacts.

Stakeholder-specific communication should connect strategy to operational risk, outcomes, responsibilities, and impacts so managers can commit and act. Technical architecture alone may not establish relevance, exclusion weakens ownership, and unexplained mandates do not create sustainable execution.

Question 27 (CISM3-027)

Correct answer: C - Reassess objectives, threats, dependencies, and capability gaps created by the acquisition.

The acquisition materially changes customers, data, transactions, obligations, threats, and architecture dependencies, requiring renewed strategic analysis. Reusing the old strategy preserves misalignment, early product purchases may not address prioritized needs, and local technical teams cannot assume enterprise strategy ownership.